

Software Supply Chain Security SBOM, SLSA, Scorecard

IoTsf Webinar - Sep 2025



“How do we know that
you’re secure?”

The software supply chain security trifecta



Hi, I'm Chris

@cpswan

<https://chris.swanz.net>



Agenda

- Gathering our ingredients - SBOM
- Precise preparation - SLSA
- Ensuring kitchen hygiene - Scorecard





OpenSSF

OPEN SOURCE SECURITY FOUNDATION

<https://openssf.org/>



Software Bill of Materials - SBOM



<https://www.cisa.gov/sbom>

Executive Order 14028

THE WHITE HOUSE



MAY 12, 2021

Executive Order on Improving the Nation's Cybersecurity



BRIEFING ROOM



PRESIDENTIAL ACTIONS



EU Cyber Resilience Act (CRA)

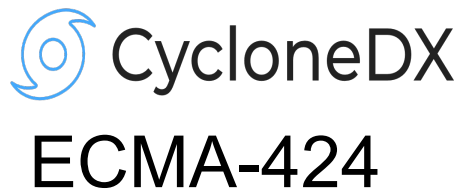


- Dec 2027
- Must include top level dependencies
- In a machine readable format
- GDPR style fines: €15M or 2.5% worldwide turnover (whichever higher)

<https://openssf.org/public-policy/eu-cyber-resilience-act/>



Two competing standards :(



*"There can be no peace until they renounce their
Rabbit God and accept our Duck God."*

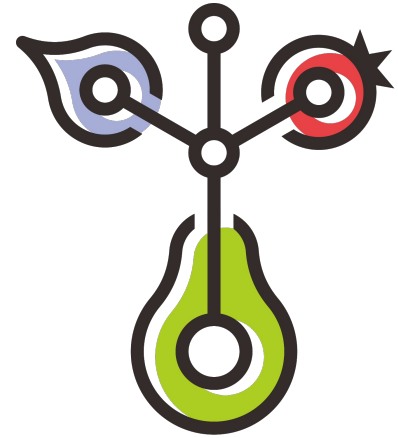
Make with Syft or Trivy, understand with GUAC



<https://github.com/anchore/syft>



<https://trivy.dev/>



GUAC

<https://guac.sh/>



Easy if you're using a modern package managed language. Not so much with traditional embedded...



CONAN
C/C++ package manager

It's a HUGE problem, especially for IoT

Lines of open source code

C	6,849,981,237
C++	2,383,678,378
...	
Rust	70,611,321



Source: openhub.net/languages (Sep 2025)

<https://media.ccc.de/v/emf2024-87-cheri-and-arm-morello>

Yocto and Zephyr can help (a lot)
and are well suited to IoT



<https://www.yoctoproject.org/>



<https://www.zephyrproject.org/>

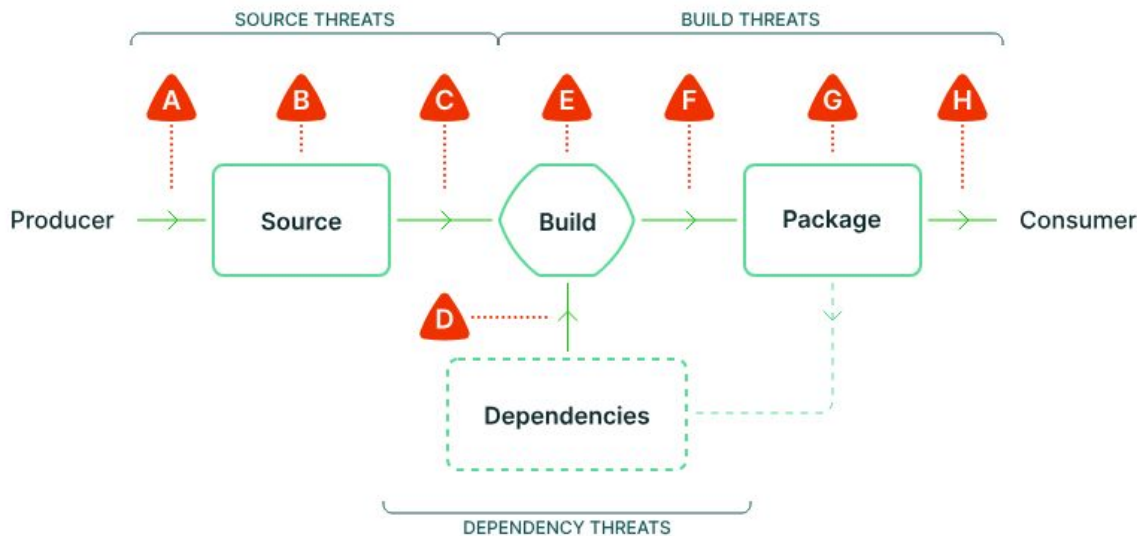


Supply-chain Levels for Software Artifacts - SLSA



<https://slsa.dev/>

Supply chain threats



SOURCE THREATS

- A** Submit unauthorized change
- B** Compromise source repo
- C** Build from modified source

DEPENDENCY THREATS

- D** Use compromised dependency

BUILD THREATS

- E** Compromise build process
- F** Upload modified package
- G** Compromise package registry
- H** Use compromised package



SLSA Build Levels

Track/Level	Requirements	Focus
Build L0	(none)	(n/a)
Build L1	Provenance showing how the package was built	Mistakes, documentation
Build L2	Signed provenance, generated by a hosted build platform	Tampering after the build
Build L3	Hardened build platform	Tampering during the build

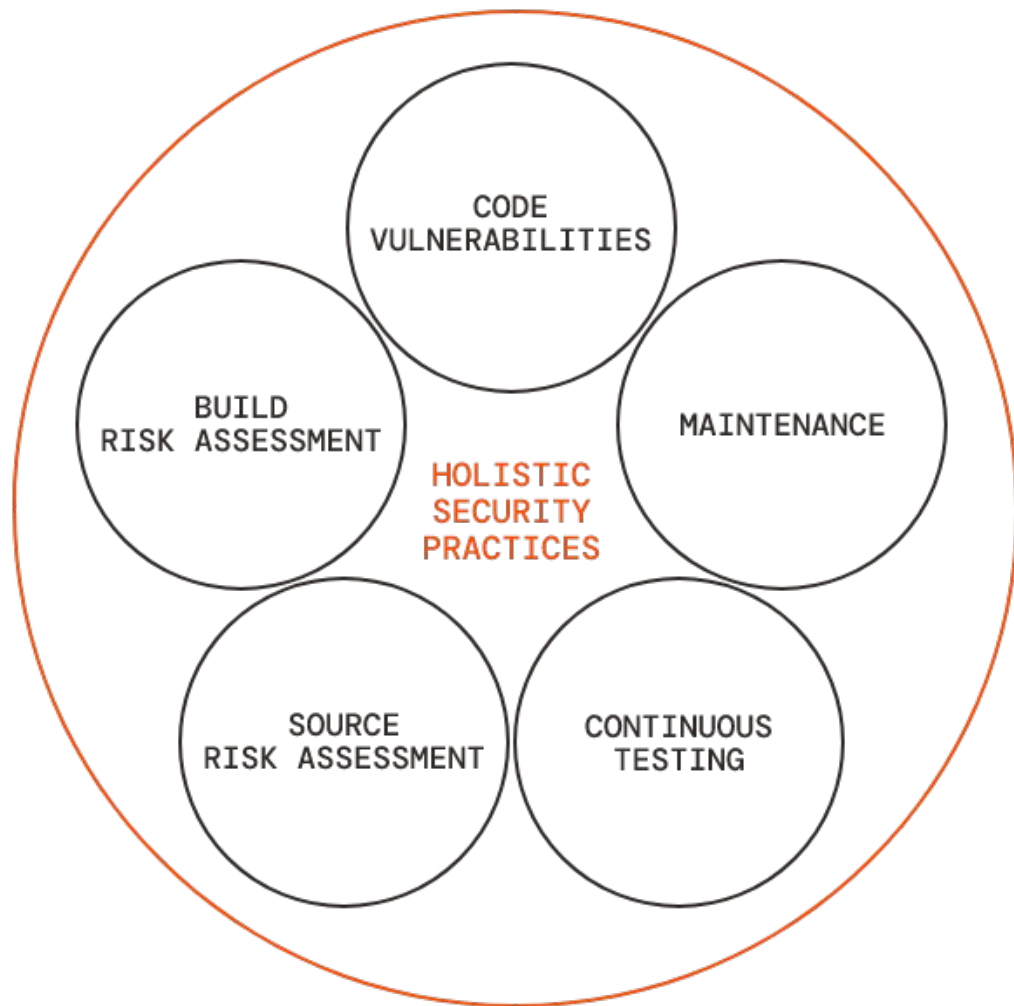


<https://slsa.dev/spec/v1.0/levels>

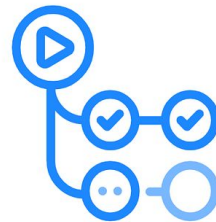
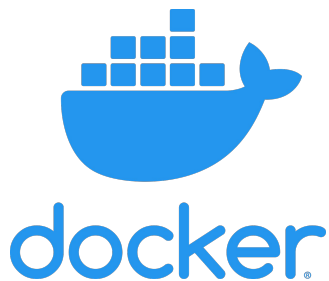
Scorecard



openssf scorecard 8.2



Dependency (pinning) hell

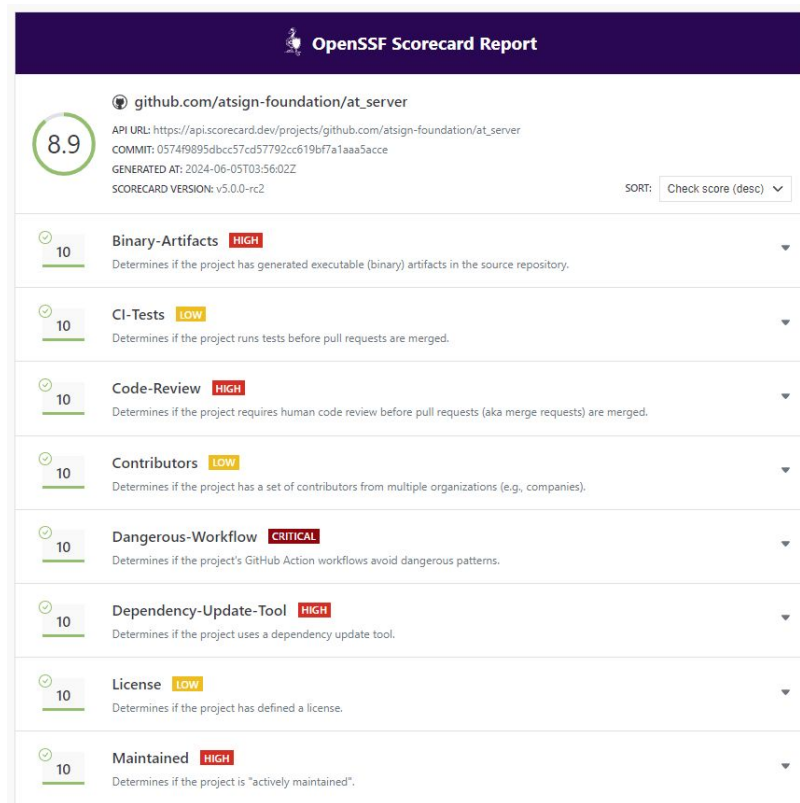


GitHub Actions



80:20

It's relatively easy to get most stuff right



There will be a residue

☐  3 Open		✓ 2 Closed	Tool ▾ Branch ▾ Rule ▾ Severity ▾ Sort ▾	
☐		SAST	Medium	trunk
#4 opened 5 months ago • Detected by Scorecard in no file associated with1				
☐		Fuzzing	Medium	trunk
#3 opened 5 months ago • Detected by Scorecard in no file associated with1				
☐		CII-Best-Practices	Low	trunk
#2 opened 5 months ago • Detected by Scorecard in no file associated with1				



How this looks to consumers

 9	Pinned-Dependencies MEDIUM	▼
Determines if the project has declared and pinned the dependencies of its build process.		
 5	Branch-Protection HIGH	▼
Determines if the default and release branches are protected with GitHub's branch protection settings.		
 5	CII-Best-Practices LOW	▼
Determines if the project has an OpenSSF (formerly CII) Best Practices Badge.		
 0	Fuzzing MEDIUM	▼
Determines if the project uses fuzzing.		
? 1	Signed-Releases HIGH	▼
Determines if the project cryptographically signs release artifacts.		

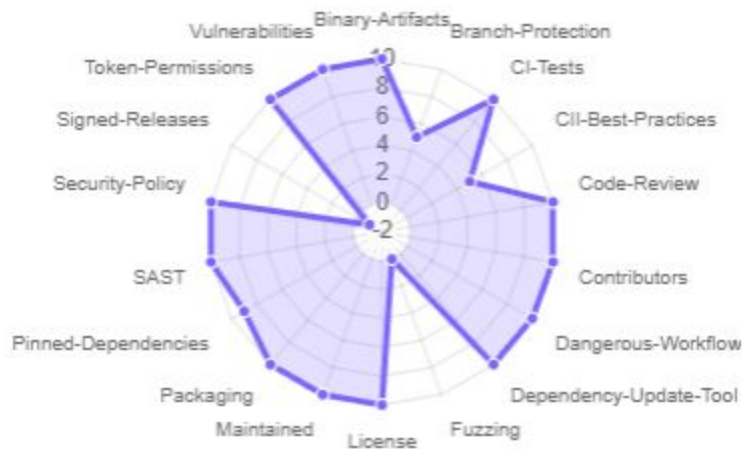


Radar plot

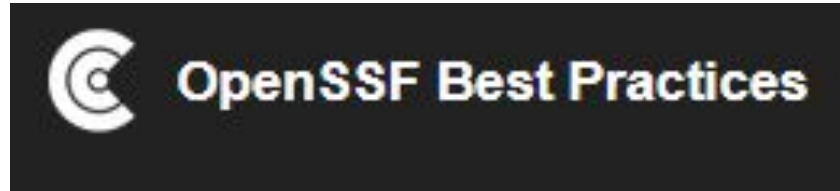
Scorecard Results

Overall Score: 8.9

Checks



This is where it gets really gnarly



openssf best practices in progress 84%

▼ Basics	13/13 ●
▼ Change Control	8/9 ●
▼ Reporting	8/8 ●
▼ Quality	11/13 ●
▼ Security	14/16 ●
▼ Analysis	2/8 ●



Review

- SBOM - knowing that you have the right ingredients
- SLSA - showing that there's care in preparation
- Scorecard - ensuring kitchen hygiene



Resources

Blog posts

<https://blog.thestateofme.com/2024/07/22/supply-chain-security-trifecta-sbom-slsa-scorecard/>

<https://blog.thestateofme.com/2022/12/02/implementing-ossf-scorecards-across-a-github-organisation/>

<https://blog.thestateofme.com/2023/03/09/roll-up-rollup-get-your-dependabot-prs-together-here/>

atGitHub

<https://github.com/at-sign-foundation/github/blob/trunk/docs/atGitHub.md>



Varun Sharma's (Step Security) QCon Demo Org

<https://github.com/qcon-demo-org>



Thanks for your time

chris@atsign.com

@cpswan



Questions?